

| 作业

2023080904007 吕乐彬

第三章 用户认证



电子科技大学
University of Electronic Science and Technology of China

作业

1. 列举并简单描述口令保密的主要威胁。

口令保密的主要威胁如下：

1. 暴力破解攻击

攻击者通过自动化工具尝试大量密码组合，尤其是针对简单或短密码进行持续猜测。

举例：

```
import itertools
import string

def brute_force(target_password, max_length=4):
    chars = string.digits # 仅尝试数字组合
    for length in range(1, max_length + 1):
        for attempt in itertools.product(chars, repeat=length):
            guess = ''.join(attempt)
            if guess == target_password:
                return f"密码破解成功: {guess}"
    return "破解失败"

# 示例：尝试破解目标密码"123"
print(brute_force("123", max_length=3))
```

2. 字典攻击

使用常见密码列表进行高效猜测，针对用户设置弱密码的行为。

假设有字典文件dict_file：

```
def dictionary_attack(target_password, dict_file="common_passwords.txt"):
    with open(dict_file, 'r') as f:
        for line in f:
            guess = line.strip()
            if guess == target_password:
```

```

        return f"密码匹配: {guess}"
    return "字典中未找到匹配密码"

# 示例: 假设字典文件包含"password", "123456"等
print(dictionary_attack("password"))

```

3. 钓鱼攻击

伪造合法登录页面或发送欺诈信息，诱骗用户主动输入密码。

4. 中间人攻击/窃听

在不安全网络中截获通信，获取传输中的未加密密码。

```

from scapy.all import sniff, TCP, Raw

def packet_handler(packet):
    if packet.haslayer(TCP) and packet.haslayer(Raw):
        payload = packet[Raw].load.decode(errors='ignore')
        if "password=" in payload:
            print(f"捕获到密码传输: {payload}")

# 启动嗅探 (需root权限)
sniff(filter="tcp port 80", prn=packet_handler, store=0)

```

5. 密码存储不当

系统使用弱哈希算法或未加盐存储密码哈希，导致破解风险增加。

安全做法：

```

import hashlib

def store_password_unsafe(password):
    return hashlib.md5(password.encode()).hexdigest()

# 安全做法: 使用加盐的SHA-256
import os
def store_password_safe(password):
    salt = os.urandom(32) # 生成随机盐值
    hashed = hashlib.pbkdf2_hmac('sha256', password.encode(), salt, 100000)
    return salt + hashed

```

6. 社会工程学

通过心理操纵（如冒充信任方）欺骗用户自愿泄露密码。

7. 密码重用

用户在不同平台使用相同密码，一旦某一平台泄露，其他账户面临连带风险。

8. 恶意软件

键盘记录程序或木马感染设备，直接捕获用户输入的密码。

```
import keyboard

def keylogger():
    log = []
    keyboard.on_press(lambda e: log.append(e.name))
    keyboard.wait() # 持续监听
```

9. 内部威胁

组织内部人员因疏忽或恶意行为导致密码泄露。

10. 弱密码策略

缺乏复杂度要求，导致用户设置易猜测的密码。

11. 物理偷窥

攻击者直接观察用户输入密码的场景。

第四章 访问控制



作业

1. 简述DAC 与MAC的区别。
2. 在访问控制语境中，主体与客体的区别是什么?什么是访问权?

1. DAC与MAC的区别

- DAC:

- 权限由资源所有者自主分配，例如文件所有者可以决定其他用户对该文件的访问权限（如读、写）。
- 灵活性高，但安全性较低，可能存在权限滥用风险。
- 常见于普通操作系统（如Linux、Windows）。

- MAC:

- 权限由系统强制管理，基于预定义的安全策略（如安全等级、标签）。
- 用户无法自行修改权限，安全性高，适用于高敏感环境（如军事、政府机构）。
- 典型应用包括SELinux、多级安全模型。

核心区别：DAC的权限由用户控制，MAC的权限由系统强制实施且不可绕过。

2. 主体、客体与访问权的定义

- **主体：**发起访问请求的主动实体，如用户、进程或应用程序。

- **客体**：被访问的被动资源，如文件、数据库、网络端口等。
- **访问权**：主体对客体执行特定操作的权限，包括读、写、执行等。访问权通过访问控制列表或安全策略定义，确保资源在授权范围内被合法使用。